

Northgate University

Information Security Risk Management Policy

An ISO/IEC 27001:2013 aligned document · Internal Use Only

Document Reference	NGU-POL-IRM01
Version	1.0
Classification	Internal Use Only
Issue Date	01 June 2026
Policy Owner	Chief Information Security Officer
Approved By	Information Governance Board
Next Review Date	01 June 2027
Aligned Standard	ISO/IEC 27001:2013 — Clauses 6.1.2, 6.1.3, 8.2, 8.3

1. Purpose

This policy defines how Northgate University ("the University") identifies, assesses, treats, and monitors information security risk. It establishes the University's commitment to a structured, risk-based approach to protecting the confidentiality, integrity, and availability of information, and ensures that risk decisions are made consistently, documented, and aligned with the University's objectives and its obligations under ISO/IEC 27001:2013.

2. Scope

This policy applies to all information assets owned or managed by the University and to all staff, students, contractors, and third parties who process University information. It governs the management of information security risk across all University systems, services, and locations, including remote and cloud-hosted environments.

3. Policy Statement and Principles

The University manages information security risk in accordance with the following principles:

- Risk management is a continuous process, not a one-off exercise.
- Risk decisions are based on a consistent assessment of likelihood and impact against defined criteria.
- Every information asset has an accountable owner who is responsible for the risks to that asset.
- All information security risks are recorded in a central risk register and reviewed on a defined cycle.
- Risk treatment is prioritised by risk level, and residual risk is formally accepted by the relevant risk owner.
- Risk management is integrated into project, change, and procurement processes.

4. Risk Management Framework

The University's risk management approach aligns with ISO/IEC 27001:2013 (Clauses 6.1.2 Information security risk assessment and 6.1.3 Information security risk treatment) and draws on the guidance of ISO/IEC 27005 and ISO 31000. The detailed process — including the assessment scales, the risk scoring matrix, and the treatment workflow — is defined in the Information Security Risk Management Methodology (NGU-POL-4.1), which operates under this policy.

5. Risk Appetite and Evaluation Criteria

The University has a low tolerance for risks affecting personal data, safety, regulatory compliance, or the availability of critical services, and prioritises their treatment. A higher tolerance may be accepted for risks to non-sensitive, internal information where the cost of mitigation is disproportionate to the benefit, subject to risk-owner acceptance. Risk is scored as likelihood multiplied by impact, each rated on a scale of 1 to 5, and evaluated against the criteria below:

Risk Level	Risk Score (Likelihood × Impact, 1–25)	Risk Appetite & Required Action
Low	1 – 6	Acceptable. Routine monitoring; treatment optional.
Medium	7 – 12	Tolerable. A treatment plan is recommended; the risk owner must be aware of and accept any residual risk.
High	13 – 25	Unacceptable without treatment. A documented treatment plan and formal risk-owner acceptance of residual risk are mandatory. High risks are escalated to the Information Governance Board.

6. Risk Assessment Requirements

- Information security risk assessments are performed at least annually for all in-scope information assets.
- Assessments are also triggered by significant change — new systems or services, major changes to existing systems, new or emerging threats, or significant security incidents.
- Assessments follow an asset-based approach, evaluating threats and vulnerabilities against the confidentiality, integrity, and availability of each asset.
- Risk owners are responsible for ensuring that assessments of their assets are completed and kept current.

7. Risk Treatment Requirements

For each identified risk, one of the following treatment options is selected:

- **Modify (reduce).** Apply or strengthen controls to reduce the likelihood and/or impact of the risk.
- **Retain (accept).** Knowingly accept the risk where it falls within appetite, with documented risk-owner approval.
- **Avoid.** Discontinue, or decide not to begin, the activity that gives rise to the risk.
- **Share (transfer).** Share the risk with a third party, for example through insurance or contractual arrangements.

Controls selected to modify a risk must be reflected in the Statement of Applicability. Each treated risk must record a residual risk score, and residual risk must be formally accepted by the risk owner. Where residual risk remains High, it must be escalated to the Information Governance Board.

8. Risk Register and Reporting

- A central information security risk register is maintained as the single source of truth for information security risks.
- A named Risk Register Owner is accountable for maintaining and updating the register.
- The register is reviewed at least quarterly; High-rated risks are reported to the Information Governance Board each cycle with documented outcomes.
- Risk status, treatment progress, and residual risk are tracked through to closure.

9. Roles and Responsibilities

- **Information Governance Board.** Approves this policy, sets the University's risk appetite, and oversees the overall information security risk profile.
- **Chief Information Security Officer (CISO).** Owns this policy and the risk management framework and reports the risk profile to the Board.
- **Information Security Risk Manager / Risk Register Owner.** Maintains the risk register, coordinates assessments, and drives treatment to completion.
- **Information Asset Owners (IAOs).** Identify, assess, and accept risks to their assets and ensure agreed treatment is implemented.
- **Internal Audit.** Provides independent assurance over the effectiveness of the risk management process.
- **All staff, students, and third parties.** Report information security risks and incidents promptly.

10. Compliance and Enforcement

Compliance with this policy is mandatory. Risks must not be accepted outside the criteria defined here without Information Governance Board approval. Failure to comply may result in disciplinary action and, for third parties, may constitute a breach of contract.

11. Related Policies and Standards

- Information Security Risk Management Methodology (NGU-POL-4.1)
- Information Classification Policy (NGU-POL-8.2)
- Information Asset Owners Handbook
- Information Security Policy
- ISO/IEC 27001:2013 — Clauses 6.1.2, 6.1.3, 8.2, 8.3
- ISO/IEC 27005:2018 (information security risk management)
- ISO 31000:2018 (risk management — principles and guidelines)

12. Policy Review

This policy will be reviewed at least annually, or sooner in response to significant organisational, legal, regulatory, or technological change. The Chief Information Security Officer is responsible for initiating the review.

13. Document Version History

Version	Date	Author	Summary of Change
1.0	01 June 2026	Chief Information Security Officer	Initial issue. Establishes the information security risk management framework.